MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 009 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · CMMC LEVEL 2

The System Security Plan an Assessor Actually Reads

Most SSPs are written to be filed, not read. Here is how a C3PAO assessor moves through the document, and what they are checking at each stop.

BY **MACTECH SOLUTIONS** READING TIME · 4 MIN CMMC · NIST-800-171 · SSP · COMPLIANCE

An assessor does not read your System Security Plan front to back. They read it the way a lawyer reads a contract they expect to litigate: skipping to the clauses that decide the case, and checking whether the rest contradicts them.

Knowing which clauses those are changes how the document should be written. Most SSPs are organized for the convenience of the person assembling them - 110 control narratives in numerical order, each a paragraph long, all of equal weight. That structure is legible to nobody, least of all to the person who has two days to determine whether your program is real.

FIELD COPY
ISSUE Nº 009
CMMC

4 min

READING TIME, NO PAYWALL, NO POP-UPS

◆ THE DOCUMENT THAT CANNOT BE DELEGATED

An SSP can be drafted with help, but it describes decisions only the organization can make - where the boundary sits, who is accountable, what is out of scope and why. A template cannot answer those.

Stop one: the boundary diagram

The assessor turns to the system description and the boundary diagram before anything else, because every other claim in the document is conditional on it. If the boundary is wrong, all 110 narratives are describing controls applied to the wrong things.

They are checking a specific thing: whether the diagram and the prose agree, and whether both agree with what they will see when they ask to log in. A diagram showing a clean CUI enclave is worth very little if the narrative later mentions that engineers occasionally pull drawings onto local workstations to work offline. That sentence, buried on page 40, has just redrawn your boundary to include every laptop in the company - and the assessor will notice it, because contradictions are what they are trained to find.

The practical implication: write the boundary section last, after every control narrative is done, and then reread the narratives specifically hunting for sentences that expand it. There will be some. There always are.

Stop two: the controls you said were not applicable

Non-applicability is where inexperienced programs lose assessments. Every control marked N/A is an assertion that carries a burden of proof, and assessors go there early because it is the highest-yield place to find weakness.

The failure mode is almost never a dishonest N/A. It is an unjustified one - a control marked not applicable with a one-line rationale that restates the claim instead of supporting it. "N/A - we do not use wireless" is a claim. "N/A - wireless is disabled in Group Policy across the enclave, enforced by the baseline at *[reference]*, verified in the monthly configuration audit" is a rationale with evidence hanging off it.

Assume every N/A will be challenged, because the ones that are easy to challenge always are.

Stop three: whether the POA&M and the SSP describe the same organization

The Plan of Action and Milestones is read against the SSP, not on its own, and the assessor is looking for one specific inconsistency: controls the SSP describes as implemented that the POA&M also lists as in progress.

That contradiction is common and it is worse than an honest gap. It tells the assessor that the two documents were maintained by different people at different times and reconciled by nobody - which raises the question of what else in the SSP is describing an intended state rather than an operating one.

A POA&M with real dates, named owners, and a few items that have visibly slipped and been re-baselined reads as an operating program. A POA&M that is empty, or whose every milestone falls conveniently after the assessment window, reads as a document produced for the assessment.

What this means for how you write it

The SSP is not a compliance artifact that happens to describe your system. It is a description of your system that happens to satisfy a compliance requirement, and the difference shows up in every paragraph.

Written the first way, it drifts the moment the environment changes, because nothing about the organization's actual work depends on it being accurate. Written the second way, it drifts too - but somebody notices, because the document is the thing engineers consult when they need to know where the boundary is.

That is the honest limit of any SSP advice, including this: a document maintained on the same cadence as the systems it describes will pass an assessment almost incidentally. One maintained on the cadence of assessments will fail eventually, no matter how well it is written the first time.

MacTech authors SSPs as a fixed-scope engagement - the boundary work, the narratives, and the POA&M reconciliation together, because separating them is what produces the contradictions above. It is listed in the Market, or talk to a director about scope. ◆ ◆
